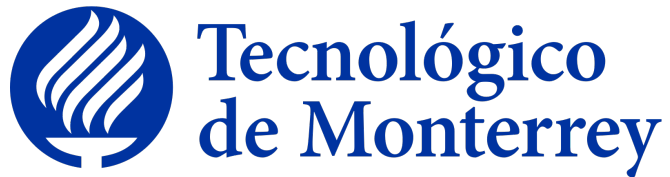


Instituto Tecnológico y de Estudios Superiores de Monterrey

Campus Monterrey



Escuela de Ingeniería y Ciencias

Ingeniería en Ciencias de Datos y Matemáticas

Bloque: Uso de Álgebras Modernas para Seguridad y Criptografía

Reporte Ejecutivo

Etapas 1 del Reto: Gestor de Identidades

Socio Formador: Casa Monarca, Ayuda Humanitaria al Migrante, A.B.P.

Profesores: Raúl Gómez, Anas Wajid y Alberto F. Martínez

Equipo de trabajo: Equipo 5

Grupo: 603

Integrantes

Alberto Rodríguez Reyes (A01383805)

Diego Alberto Rodríguez Ruiz (A01571638)

Rubén Jiménez Sarmiento (A01286256)

Hector Alonso Flores Meléndez (A01571545)

Valeria García Hernández (A01742811)

Lugar y fecha de elaboración: Monterrey, Nuevo León, 30 de abril de 2026

Índice general

1. Resumen Ejecutivo	1
2. Objetivos vs Resultados	2
2.1. Qué se cumplió	2
2.2. Qué se modificó o adaptó	3
2.3. Pendientes para siguientes versiones	3
3. Solución Implementada	4
3.1. Qué hace la aplicación	4
3.2. Usuarios e impacto generado	4
3.3. Alcance final de la aplicación	4
4. Impacto de Negocio	5
4.1. Ahorro de tiempo y reducción de gestiones manuales	5
4.2. Incremento en productividad	5
4.3. Reducción de errores y riesgos	5
4.4. Métricas antes vs. después	6
5. Lecciones y Hallazgos	7
5.1. Qué funcionó bien	7
5.2. Qué se puede mejorar	7
5.3. Riesgos detectados	7
6. Estado Actual y Próximos Pasos	9
6.1. Estado actual	9
6.2. Recomendaciones	9
7. Referencias	11

Capítulo 1

Resumen Ejecutivo

Casa Monarca, Ayuda Humanitaria al Migrante, A.B.P., organización con sede en Monterrey dedicada a la atención integral de personas migrantes, requería centralizar la administración de identidades y permisos de su personal, así como dotar de respaldo criptográfico a los procesos de autorización y firma de documentos institucionales relacionados con la atención a migrantes. Antes del proyecto, la asignación de accesos y la validación de la identidad de coordinadores se realizaba de manera informal, sin un mecanismo único que controlara estados de cuenta, vigencias o certificados de identidad.

Objetivo inicial. El objetivo del bloque consistió en diseñar e implementar la Etapa 1 del reto “Gestor de Identidades”: un sistema de autenticación y control de acceso basado en roles (RBAC), con generación de certificados digitales únicos por usuario y validación de vigencia y estado de cuenta, fundamentado en conceptos de hashing seguro, entropía (Shannon) y recomendaciones del NIST para criptografía de llave pública.

Qué se desarrolló. El equipo construyó una aplicación web completa —frontend en React con Vite y backend en PHP 8.2 sobre MySQL/MariaDB— que cubre el alcance original de identidades y, además, incorpora un módulo criptográfico adicional basado en OpenSSL: generación de pares de llaves RSA-2048 para coordinadores, cifrado de la llave privada con contraseña, firma digital SHA-256 de documentos y verificación criptográfica de dichas firmas, junto con módulos complementarios de gestión de migrantes y de aprobación de solicitudes (“solicitudes push”).

Resultado logrado. La validación funcional se realizó mediante 15 casos de prueba de caja negra que cubren inicio de sesión, control de acceso por rol, operaciones CRUD sobre usuarios y la persistencia de certificados y vigencias, con resultados “Pass” en los escenarios documentados con evidencia.

Impacto principal. La centralización y trazabilidad del control de acceso e identidad del personal de Casa Monarca, así como la creación de una base criptográfica sólida —firma digital, hashing seguro y certificados— para validar documentos oficiales del flujo de atención a migrantes.

Estado actual. El sistema se encuentra en estado de prototipo funcional / piloto, validado en un ambiente local de desarrollo, y listo para iniciar pruebas de aceptación junto con el socio formador.

Capítulo 2

Objetivos vs Resultados

2.1. Qué se cumplió

La Etapa 1 cubrió de manera completa los objetivos centrales del “Gestor de Identidades”: autenticación segura, control de acceso por rol, generación de certificados digitales y validación de estado/vigencia, además de un panel administrativo funcional para la gestión de usuarios. La siguiente tabla resume los objetivos planteados frente a los resultados obtenidos.

Tabla 2.1: Objetivos vs. resultados del proyecto

Objetivo inicial	Resultado obtenido	Observación
Autenticación segura de usuarios	Login con verificación de credenciales mediante <code>password_hash</code> / <code>password_verify</code> (BCRYPT)	Cumplido
Control de acceso basado en roles (RBAC)	4 roles (admin, coordinador, operador, consulta) con rutas protegidas en frontend y validación en cada endpoint	Cumplido
Certificados digitales únicos por usuario y control de vigencia/estado	Generación automática de <code>certificado_codigo</code> y validación de estado (activo/inactivo/revocado) y <code>fecha_vigencia</code> en cada login	Cumplido
CRUD de usuarios desde panel administrativo	AdminPanel con alta, edición y baja de usuarios, asignación de rol, estado, vigencia y coordinador asociado	Cumplido
Aplicar conceptos de criptografía de llave pública (NIST, entropía de Shannon)	Módulo OpenSSL: generación de llaves RSA-2048 por coordinador, llave privada cifrada con contraseña, firma y verificación SHA-256 de documentos	Ampliado más allá del alcance original
Validación funcional del sistema	15 casos de prueba de caja negra; 13 con evidencia completa; resultados “Pass” en todos los escenarios documentados	Cumplido

2.2. Qué se modificó o adaptó

Durante el desarrollo, el equipo extendió el alcance original al integrar un módulo completo de firma digital de documentos con OpenSSL (RSA-2048 + SHA-256), que va más allá del RBAC y los certificados inicialmente planteados. Esta extensión surgió de la necesidad del socio formador de contar con un mecanismo verificable para la autorización de documentos institucionales. Asimismo, se incorporaron los módulos de gestión de migrantes y solicitudes push como parte del flujo operativo completo del sistema.

2.3. Pendientes para siguientes versiones

- Completar la evidencia de los casos de prueba 4 y 15 (imágenes 37 a 39 no anexadas).
- Extender el plan de pruebas a los módulos de firma digital, migrantes y solicitudes push.
- Realizar pruebas de aceptación con el socio formador en un entorno de producción.
- Migrar la configuración sensible a variables de entorno para facilitar el despliegue en distintos ambientes.

Capítulo 3

Solución Implementada

3.1. Qué hace la aplicación

El **Gestor de Identidades** es una aplicación web full-stack que centraliza cuatro procesos principales de Casa Monarca:

1. **Gestión de identidades y accesos:** creación, edición, activación, desactivación y revocación de usuarios con certificado digital único y fecha de vigencia controlada.
2. **Control de acceso por roles (RBAC):** cuatro roles (admin, coordinador, operador, consulta) con permisos diferenciados tanto en el frontend (rutas protegidas) como en el backend (validación en cada endpoint).
3. **Flujo documental con firma criptográfica:** los documentos avanzan por cuatro etapas (Ventanilla → Operador → Coordinador → Inserción final). El paso de Operador a Coordinador requiere la firma digital RSA-2048 del coordinador asignado, cuya integridad se verifica con SHA-256.
4. **Registro de migrantes y solicitudes push:** captura de información operativa de personas atendidas y flujo de aprobación delegado entre personal y coordinadores.

3.2. Usuarios e impacto generado

- **Administradores:** gestión completa de usuarios (CRUD), visualización global de documentos y ejecución de la inserción final del flujo documental.
- **Coordinadores:** supervisión de su coordinación, firma de documentos con autenticación reforzada mediante certificado y clave, y solicitud de firmas adicionales a otros coordinadores.
- **Operadores:** captura de migrantes y documentos en las primeras etapas del flujo (Ventanilla).
- **Personal de consulta:** acceso de solo lectura al panel, migrantes y documentos.

3.3. Alcance final de la aplicación

La aplicación quedó implementada como una solución full-stack desplegable sobre un ambiente tipo LAMP/MAMP (Apache 2.4, PHP 8.2, MariaDB/MySQL 10.4, phpMyAdmin), con un esquema de base de datos que incluye las tablas usuarios, documentos, documentos_firmas, documentos_historial y migrantes. Este esquema soporta control de acceso por roles, firma criptográfica multi-coordinador y trazabilidad completa de los cambios de etapa de cada documento.

Capítulo 4

Impacto de Negocio

4.1. Ahorro de tiempo y reducción de gestiones manuales

Antes del proyecto, la asignación y revocación de accesos del personal de Casa Monarca dependía de gestiones manuales sin un panel centralizado. Con el Gestor de Identidades, el equipo administrativo puede crear, editar, activar, desactivar o revocar usuarios en segundos, con generación automática de certificado y, cuando corresponde, de llaves criptográficas para coordinadores.

4.2. Incremento en productividad

La verificación de identidad de los coordinadores y la firma de documentos ocurren dentro del mismo flujo digital, eliminando la necesidad de recabar firmas físicas o realizar validaciones manuales por separado. El flujo documental de cuatro etapas (Ventanilla → Operador → Coordinador → Inserción final) estandariza y agiliza el avance de cada documento desde su captura hasta su resguardo final.

4.3. Reducción de errores y riesgos

- Las contraseñas se almacenan únicamente como hash BCrypt, nunca en texto plano.
- El acceso a funciones administrativas y de firma está restringido por rol tanto en el frontend (rutas protegidas) como en el backend (validación en cada endpoint).
- La firma digital basada en RSA-2048 y SHA-256 garantiza la integridad de los documentos: cualquier modificación posterior al archivo invalida la firma, y su validez puede comprobarse de forma objetiva.
- La validación automática de estado (activo/inactivo/revocado) y vigencia evita que cuentas vencidas o revocadas accedan al sistema, tal como se confirmó en los casos de prueba 9, 10 y 11.

4.4. Métricas antes vs. después

Tabla 4.1: Comparativo de indicadores antes y después del sistema

Indicador	Antes (proceso manual)	Después (Gestor de Identidades)
Verificación de identidad de coordinador	Sin mecanismo formal documentado	Certificado único + clave adicional + verificación criptográfica (RSA/SHA-256)
Validación de documentos oficiales	Firma física, sin trazabilidad digital	Firma digital RSA-2048 + SHA-256, verificable, con folio y bitácora de etapas
Control de acceso por rol	Manual / informal	RBAC con 4 roles, rutas protegidas y validación en cada endpoint
Altas, bajas y cambios de acceso de personal	Sin certificado ni control formal de vigencia	Automatizado: certificado, vigencia y estado por usuario desde un panel único
Cobertura de pruebas funcionales del módulo de identidades	0 casos documentados	15 casos de prueba de caja negra (13 con evidencia completa)

Capítulo 5

Lecciones y Hallazgos

5.1. Qué funcionó bien

- El uso de `mysqli` con sentencias preparadas en todos los endpoints mitigó los riesgos de inyección SQL (alineado con el OWASP Top 10), validado a través de los 15 casos de prueba ejecutados.
- `password_hash` y `password_verify` con BCrypt cumplieron el objetivo de no almacenar credenciales en texto plano, validado en los casos de inicio de sesión correcto e incorrecto.
- La integración de OpenSSL para generar pares RSA-2048, cifrar la llave privada con una contraseña y firmar/verificar documentos con SHA-256 demuestra la aplicación práctica de los conceptos de álgebra moderna y criptografía asimétrica del bloque, así como de las recomendaciones de NIST SP 800-56B para el manejo de pares de llaves.
- La separación en tres capas (presentación, lógica de negocio y datos) facilitó dividir el trabajo entre los integrantes del equipo y probar cada módulo de forma independiente.

5.2. Qué se puede mejorar

- **Configuración codificada de forma fija:** las credenciales de la base de datos y la ruta de configuración de OpenSSL están atadas a una instalación local de MAMP, lo que dificulta migrar el sistema a otro entorno sin modificar el código.
- **Política CORS inconsistente entre endpoints:** algunos permiten cualquier origen (`Access-Control-Allow-Origin: *`) y otros restringen a `http://localhost:5173`; conviene unificar y endurecer esta configuración.
- La evidencia documental de los casos de prueba 4 y 15 quedó incompleta (imágenes 37 a 39 referenciadas pero no anexadas).

5.3. Riesgos detectados

- El acceso CORS abierto (*) en varios endpoints representa un riesgo si la API llegara a exponerse fuera de un entorno controlado.
- Las llaves privadas de los coordinadores se cifran con una contraseña de mínimo 6 caracteres, lo cual podría ser insuficiente frente a ataques de fuerza bruta en caso de filtración de la base de datos.

- El frontend depende de `localStorage` para mantener la información de sesión del usuario (id y rol), por lo que es indispensable que el backend valide siempre estos datos de forma independiente en cada solicitud.

Capítulo 6

Estado Actual y Próximos Pasos

6.1. Estado actual

El sistema se encuentra en estado de **prototipo funcional / piloto**. El módulo de identidades fue probado en un ambiente local (Apache 2.4, MariaDB/MySQL 10.4, PHP 8.2 y phpMyAdmin) mediante 15 casos de prueba de caja negra, la mayoría con resultado “Pass”. Los módulos adicionales —firma digital de documentos, gestión de migrantes y solicitudes push— están implementados y operativos, pero aún no cuentan con un plan de pruebas formal documentado, por lo que se consideran en fase de piloto interno previo a su validación con el socio formador.

6.2. Recomendaciones

Mejoras

- Completar la evidencia faltante de los casos de prueba 4 y 15.
- Externalizar la configuración sensible (variables de entorno) para credenciales de base de datos y configuración de OpenSSL.
- Unificar y restringir la política CORS según el ambiente (desarrollo vs. producción).

Nuevas funcionalidades

- Notificaciones automáticas de vencimiento próximo de certificado o vigencia de usuario.
- Panel de auditoría que aproveche la tabla `documentos_historial` para dar seguimiento a cambios de etapa y firmas.
- Reportes e indicadores (usuarios activos por rol, documentos por etapa, tiempos promedio de firma).

Escalabilidad

- Contenerizar la aplicación (por ejemplo, con Docker) para facilitar su despliegue fuera del entorno local actual.
- Migrar el manejo de sesión a un esquema de tokens (JWT) en lugar de depender de `localStorage`.

- Evaluar el uso de un gestor de llaves o HSM para la custodia de las llaves privadas de los coordinadores conforme crezca el número de usuarios y documentos firmados.

Capítulo 7

Referencias

- [1] Casa Monarca, Ayuda Humanitaria al Migrante, A.B.P. (s.f.). Sitio web oficial. <https://casamonarca.org.mx/>
- [2] National Institute of Standards and Technology. (2019). *Special Publication 800-56B Revision 2: Recommendation for pair-wise key establishment using integer factorization cryptography*. U.S. Department of Commerce.
- [3] Ramió Aguirre, J. (2006). *Libro electrónico de seguridad informática y criptografía* (Versión 4.1). Universidad Politécnica de Madrid.
- [4] Shannon, C. E. (2001). A mathematical theory of communication. *ACM SIGMOBILE Mobile Computing and Communications Review*, 5(1), 3–55.
- [5] The PHP Group. (s.f.). OpenSSL functions. *PHP Manual*. <https://www.php.net/manual/en/book.openssl.php>